

판정 근거 (Verdict Logic) — 1-pager

교수님 피드백 #5 — malicious HIGH confidence 판정 기준 및 설계 근거

pkgsentinel · 7팀 · 2026-05-28 · 코드 기준 (src/pkgsentinel/verdict_rules.py)

1. 판정 결정 — Verdict 6종 + 조건 (코드 line 164~222)

Verdict	판정 조건
MALICIOUS	high TTP severity ≥ 1 AND LLM $\ni$ MALICIOUS AND max(MAL conf) ≥ 0.85
HIGH_RISK	(strong TTP sim ≥ 0.85 $\vee$ version_diff critical) AND LLM $\in$ {SUS, MAL}
SUSPICIOUS	weak TTP (0.70~0.85) $\vee$ version_diff any $\vee$ LLM SUS evidence ≥ 2 (quorum)
CLEAN	위 어디에도 안 걸림. weak TTP + LLM=BENIGN 도 BENIGN 덮어씀.
ERROR	필수 stage (08 Behavior · 11 TTP · 16 LLM) 중 1 개 이상 실패 — 부분 판정 금지.
CANNOT_ANALYZE	Stage 00 에서 레지스트리 미등록 확정.

2. MALICIOUS 판정 — 3 조건 AND

셋 다 만족해야만 MALICIOUS. 하나라도 모자라면 자동으로 HIGH_RISK 이하로 강등.

- ① **high TTP** L3 (Stage 11) 의 TTP 임베딩 매칭 중 severity = HIGH 가 1 개 이상.
- ② **LLM MAL** L4 (Stage 16) Claude 3-agent 중 1 개라도 MALICIOUS 답.
- ③ **max conf ≥ 0.85** 위 LLM MALICIOUS evidence 중 가장 신뢰도 높은 것의 self-reported confidence.
→ 'max 기반' 이 중요. 평균이 아닌 max 인 이유는 §3 의 H-6 fix 참고.

3. 5가지 설계 원칙 (verdict_rules.py 주석 인용)

Trust by Verification	패키지 나이 · 인기도 · 다운로드 수 일절 미참조 (line 6). Shai-Hulud 같은 유명 패키지 감염을 봐주지 않기 위함.
부분 판정 금지	필수 stage 3 개 (08·11·16) 중 1 개라도 실패하면 ERROR (line 7). 분석 불완전 시 false negative 방지.
BENIGN 덮어쓰기	LLM 이 정상으로 본 weak TTP 매칭은 SUSPICIOUS 로 승격 안 됨 (line 10~11). False positive 억제.
max(conf) ≥ 0.85	H-6 fix. 평균을 쓰면 진짜 exfil 체인 옆에 저신뢰 잡음 1 개만 섞여도 평균이 깎여 MALICIOUS → HIGH_RISK 로 강등됐던 실제 버그. 단일 강한 증거 기준으로 변경 (line 150~159).
LLM-only quorum = 2	단일 LLM 의심 evidence 로 SUSPICIOUS 승격 안 함 (line 56~59). 대량 분석에서 FP 누적 억제.

4. 임계값 — 현재 값 + 근거 + 보강 계획

임계값	위치	현재 근거	보강
0.85	strong TTP / MAL conf	Stage 4 임베딩 cosine 분포 분석	ablation 측정 예정
0.70	weak TTP 매칭 하한	그 이하는 noise 킷	ablation 측정 예정
0.50	LLM quorum 입력 필터	그 미만은 LLM 자신도 확신 없음	경험값 유지

[v2 보강 예정] DataDog 543 fixture 에 대해 threshold 0.80/0.85/0.90 각각으로 돌려 recall / FPR / F1 측정 → optimal threshold 검증.

5. confidence 가 어디서 오는가

TTP similarity	Stage 11 — sentence-transformer (MiniLM-L6) 임베딩 cosine similarity. 0.0 ~ 1.0 연속값.
LLM confidence	Stage 16 — Claude 3-agent 응답의 self-reported confidence (0.0 ~ 1.0). 각 에이전트 (semantic/diff/dependency) 가 자신의 판정에 대한 확신도를 보고.
Rule confidence	Stage 11 의 규칙 기반 매칭 (apply_rules) 적중은 결정적이므로 1.0 으로 고정.
Evidence aggregation	단일 Evidence 객체에 (TTP severity + similarity + LLM verdict + confidence) 가 모두 묶여 들어감. 판정 함수는 이 evidence 리스트와 stage_results 만 입력으로 받음 (메타데이터 의존 X).

6. 한계 — 정직히

- 47-indicator 개별 가중치는 휴리스틱 — 학술 ablation 측정 없음.
- Agentic 자동 판별 threshold 5 점도 경험값 — FP/FN 측정 미진행.
- 임계값 0.85 / 0.70 / 0.5 의 ablation 측정 미수행 (v2 에서 보강).
- LLM self-reported confidence 의 calibration 평가 없음 (Claude 가 보고하는 0.9 가 실제로 90% 정확한지 확인 안 됨).

참고 코드: `src/pkgssentinel/verdict_rules.py` (메인 결정), `src/pkgssentinel/stages/stage4_ttp_match.py` (TTP 임베딩 + 임계값), `src/pkgssentinel/stages/stage5_multi_agent.py` (LLM 3-agent), `src/pkgssentinel/agentic/classifier.py` (매니페스트 diff).